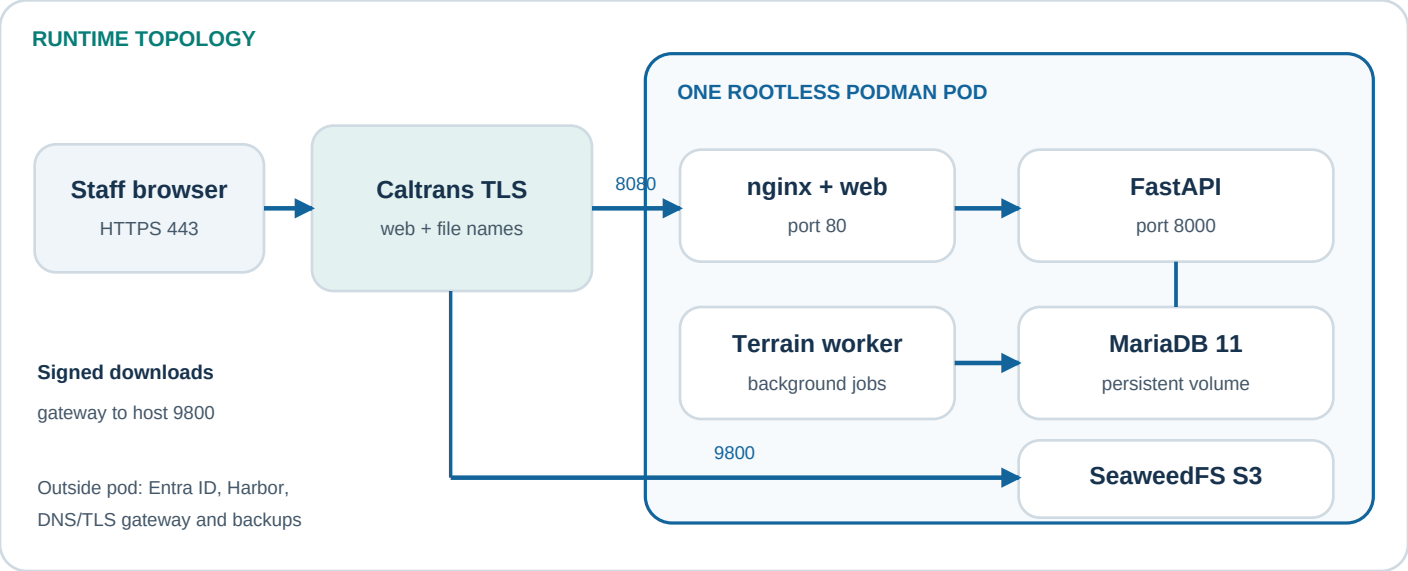
CALTRANS IT DISCUSSION / ARCHITECTURE

ERIS deployment briefing

One Linux Podman pod, five containers, two persistent data volumes. Caltrans owns the platform and security boundary; the ERIS team supplies application code and deployment artifacts.

First decision: does Caltrans mean a Podman pod on a Linux VM, or a Kubernetes/OpenShift Pod? These artifacts implement Podman. Confirm that MariaDB and object storage may run in the same pod.



Evidence uploads follow browser to FastAPI to private S3. The separate file hostname serves short-lived signed downloads through the TLS gateway.

Stack at a glance

Inside the pod	Outside the pod / Caltrans-owned
nginx + React web; Python/FastAPI API; terrain worker	DNS/TLS gateway, firewall and public HTTPS names
MariaDB 11 metadata + SeaweedFS 4.50 S3 objects	Entra ID, Jenkins, Harbor, backup and monitoring
Host publishes only 8080 (web/API) and 9800 (S3)	Gateway exposes HTTPS 443; internal DB/API ports stay private

Current Campos Labs Proxmox pod is a packaging rehearsal, not Caltrans acceptance: it uses local image tags, Cloudflare/Caddy and password sign-in. Harbor, Caltrans Entra, security policy and off-host recovery still need joint tests.

DATA / IDENTITY / SECURITY

What is implemented, and what needs approval

Area	ERIS today	Caltrans decision
Data	MariaDB holds accounts, roles, incidents, assessments, workflows and metadata. SeaweedFS holds photos, attachments, PDFs and terrain packages.	Classification, retention, legal hold, and whether to import any existing data.
Recovery	Two persistent named volumes; the database and object store must be restored together with runtime secrets.	Encrypted off-host backup, RPO/RTO, restore drill and single-host failure plan.
Entra	Web OIDC authorization code + PKCE, single tenant, exact callback. ERIS roles are local; users link by tenant + object ID.	Tenant/cloud, Web app, first admin object ID, MFA/Conditional Access tests. Current server exchange requires a client secret.
Sessions	ERIS HS256 bearer token, 120-minute default, currently kept in browser localStorage. API checks ERIS active flag and roles every request.	Review token storage, lifetime and offboarding. Entra disable alone does not revoke an already-issued ERIS token.
Files / TLS	Private S3 buckets; 15-minute signed URLs. Internal pod traffic is localhost HTTP/TCP.	TLS gateway, signed-URL forwarding, HSTS/CSP, rate limits/WAF, at-rest encryption and log redaction.
Supply chain	Jenkinsfile builds and pushes three ERIS images; IT mirrors MariaDB and SeaweedFS.	Scan/license/SBOM/signing policy, digest approval and release promotion owner.

Security gate: ERIS browser tokens are in localStorage. OWASP advises against storing authentication tokens there. If Caltrans requires HttpOnly server sessions or certificate-based Entra client authentication, plan and test those code changes before production.

First administrator and handover

Fresh install creates schema and roles, not demo users. One initial admin is seeded once, preferably linked to the supplied Entra object ID. Create and verify at least two named SSO admins, disable the initial admin, remove its temporary credential, and then disable local password sign-in in the API and rebuilt web image.

Web callback: https://<web-host>/api/auth/entra/callback. A future mobile app needs a separate native/public Entra registration and PKCE flow; it is not part of this release.

DELIVERY / ACCEPTANCE

How the deployment would go

Step	Work and evidence
1. Decide	Agree Podman interpretation, data scope, host/storage, gateway names, Entra policy, Harbor/Jenkins gates, security review and recovery targets.
2. Stage	Caltrans provisions Linux/rootless Podman, two volumes, DNS/TLS gateway, firewall/egress, Entra test registration, Harbor/Jenkins and backup target.
3. Build	On an approved Linux Podman agent, Jenkins builds and pushes API, worker and web from an immutable commit. IT mirrors MariaDB/SeaweedFS; scans/approves and pins five digests.
4. Configure	IT supplies runtime secrets through its approved channel. Set exact web, S3 and callback URLs; match DB and S3 credentials across env files.
5. Install	Run eris-pod.sh up. It initializes schema/roles, runs Alembic, creates private buckets, seeds one admin, and starts the five containers.
6. Prove	Check HTTPS web/API, evidence upload through API and signed S3 download, Entra linked/unknown/disabled users, roles, incident path, restart, reboot, matched backup/restore and rollback.
7. Handover	Verify two named Entra admins, disable initial admin and local login, rotate handover secrets, record monitoring/support owners, then schedule production cutover.

Who hands over what

ERIS team supplies	Caltrans IT supplies / approves
Approved source commit, Jenkinsfile, Podman scripts, env templates and operator runbook.	Linux host/service account, DNS/TLS gateway, private networking, firewall and egress.
Architecture/data/security packet, application tests, bootstrap and rollback procedures.	Harbor/Jenkins, mirrored third-party images, scan/sign/SBOM gate and five image digests.
Application support and fixes found during staged acceptance.	Entra app registration, secret delivery, backup/restore, logging, alerts and change approval.

Never place populated env files, passwords, robot secrets or the initial admin credential in email, tickets, images or a repository. The supplied Jenkins pipeline does not deploy or perform a complete security scan.

Ask these questions first

Priority	Question to Caltrans IT
1	Podman pod or Kubernetes/OpenShift Pod? Can DB and S3 be stateful containers in it?
1	What data classification and network zone apply? Clean install or approved data import?
1	Who owns host, rootless service account, CPU/RAM/disk, patching and SELinux policy?
1	What are the web and file HTTPS names, gateway placement, certificates and firewall rules?
1	Which Entra tenant/cloud, Web app owner, callback, first admin object ID and credential policy?
1	Will security accept localStorage JWTs, 120-minute sessions and manual ERIS offboarding?
1	Who owns Harbor/Jenkins, image mirroring, digest pinning, scans, licenses, SBOMs and signing?
1	What are the matched backup target, retention, RPO/RTO and restore-test owner?
1	Is one host's service interruption acceptable, or is a failover target required?
1	Is browser 3D ArcGIS or Esri offline processing in scope? Who supplies the restricted API key?
2	Which Entra, GIS, SMTP and future mobile services may the host and clients reach?
2	Who owns SIEM, WAF/security headers, incident response, accessibility/privacy review and go-live approval?

Likely questions from IT

They may ask	Your answer
Is it one image?	No. One Podman pod, five containers, two persistent volumes.
Who provides images?	Caltrans Jenkins builds our three images; IT mirrors MariaDB/SeaweedFS; host pulls approved Harbor digests.
SeaweedFS license?	Upstream 4.50 source is Apache-2.0; IT must review the exact image and dependencies. Enterprise is not proposed.
Is it highly available?	No. One host needs a tested matched backup and recovery plan.
Is Entra live already?	Implemented and tested in code, but not validated against Caltrans's tenant; current Proxmox uses local login.
Is mobile ready?	No Caltrans mobile release yet. Reserve API/S3 reachability; native Entra flow is future work.

Take into the meeting: this handout, the editable technical packet, Podman runbook, Jenkinsfile, env templates (unpopulated), and a specific source commit. The Jenkins job needs a Linux Podman agent, Harbor access, its push credential and capacity for a 4 GiB Node heap. After decisions: circulate hostnames/ports, approved digests, a non-secret config worksheet and staged acceptance/restore evidence.